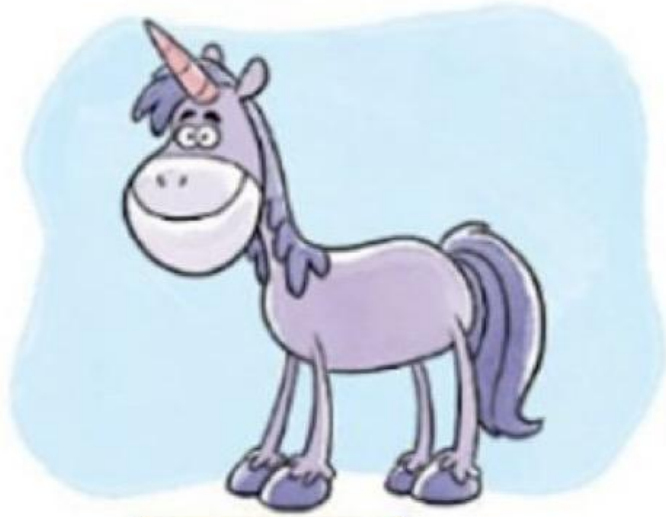
THINGS THAT DON'T EXIST:



BIGFOOT



FAIRIES



UNICORNS



Threat Models

Castle Defense 101

(aka Threat Modeling)



Bärnau Motte, Germany

"Die slawische Frühmittelaltersiedlung im Geschichtspark Bärnau-Tachov mit der Motte im Vordergrund"
by Barbara Brunner, used under CC BY-SA 3.0/ Cropped from original
https://commons.wikimedia.org/wiki/File:Motte_mit_Dorf.jpg



Bärnau Motte, Germany

“Geschichtspark Bärnau-Tachov im Jahr 2017” by Klaus Schicker, used under CC BY 4.0/ Cropped from original https://commons.wikimedia.org/wiki/File:Geschichtspark-Baernau-Luftaufnahme.jpg

“Think like an attacker” considered harmful



Malbork Castle, Poland

“Panorama of Malbork Castle, Żuławy region, Poland” by DerHexer, used under CC BY-SA 3.0
https://commons.wikimedia.org/wiki/File:Panorama_of_Malbork_Castle,_part_4.jpg



Alcatraz Island, US

“View of Alcatraz Island in August 2021” by Chris6d, used under CC BY-SA 4.0/ Cropped from original
https://commons.wikimedia.org/wiki/File:Alcatraz_2021.jpg



@OtherDevOpsGene @techbash #TechBash











“Clouds in Russia.” by Dmitry Makeev, used under CC BY-SA 4.0 https://commons.wikimedia.org/wiki/File:Clouds_in_Russia._img_469.jpg



- What are we protecting?
- Why are we protecting it?
- How might it be compromised?
- What happens if we fail to protect it?
- How will we react/respond and move on?

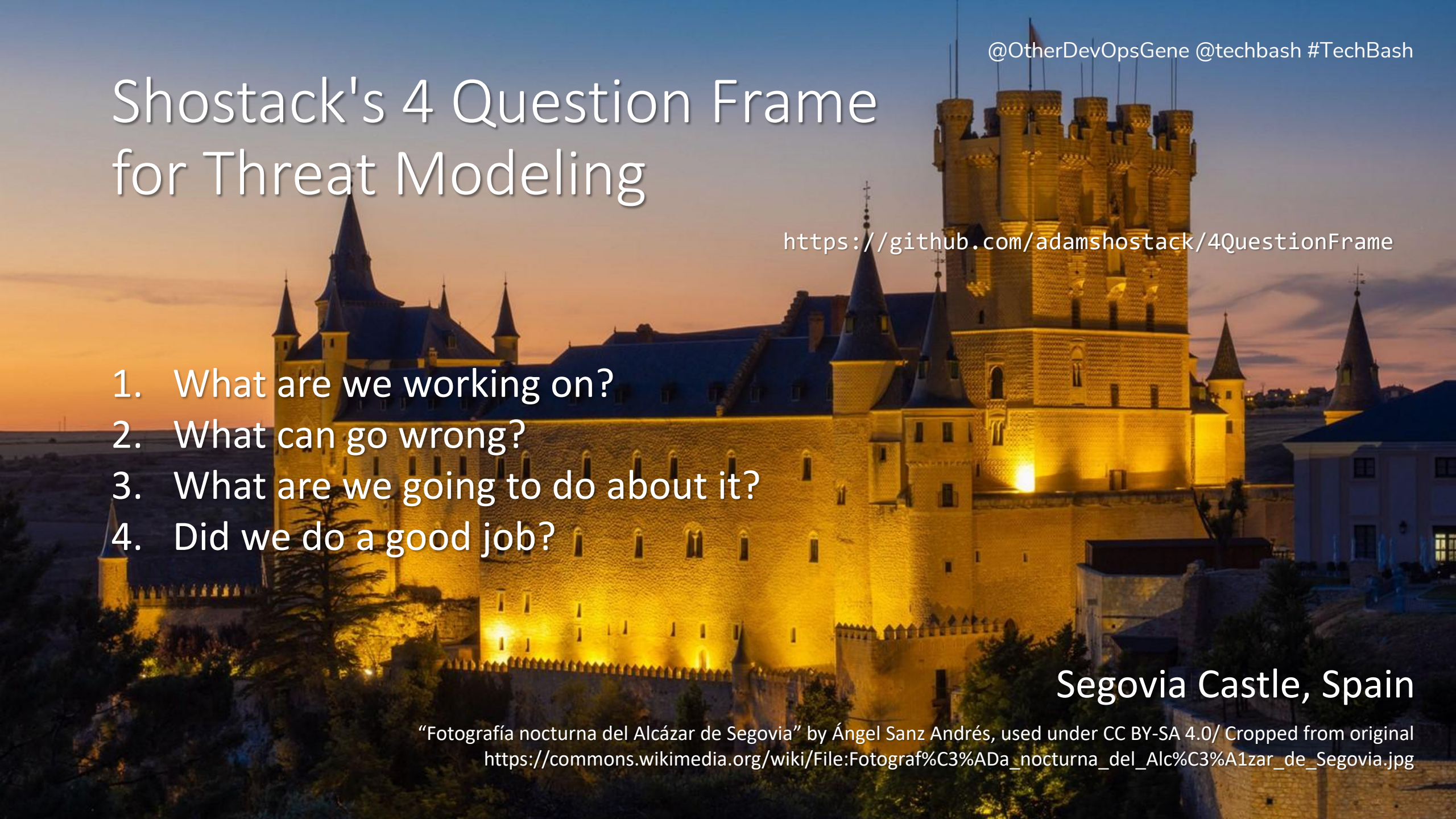
Edinburgh Castle, Scotland

"Edinburgh Castle entraince" by Graham van der Wielen, used under CC BY 2.0/ Cropped from original https://commons.wikimedia.org/wiki/File:Edinburgh_-_Old_City_-_Edinburgh_Castle_(2962379502).jpg

Shostack's 4 Question Frame for Threat Modeling

https://github.com/adamshostack/4QuestionFrame

1. What are we working on?
2. What can go wrong?
3. What are we going to do about it?
4. Did we do a good job?



Segovia Castle, Spain

“Fotografía nocturna del Alcázar de Segovia” by Ángel Sanz Andrés, used under CC BY-SA 4.0/ Cropped from original https://commons.wikimedia.org/wiki/File:Fotograf%C3%ADa_nocturna_del_Alc%C3%A1zar_de_Segovia.jpg



Castel del Monte, Italy

"Italy, Castel del Monte" by Berthold Werner, used under CC BY-SA 3.0/ Cropped from original
https://commons.wikimedia.org/wiki/File:Castel_del_Monte_BW_2016-10-14_13-15-58.jpg



Castel del Monte, Italy

“Castel del Monte fotografato con mavic mini 2” by D.belfiore, used under CC BY-SA 4.0/ Cropped from original https://commons.wikimedia.org/wiki/File:Castel_del_monte_la_corona_di_Puglia.jpg



Valère Basilica, Switzerland

"Aerial view of the Valère Basilica" by Giles Laurent, used under CC BY-SA 4.0
https://commons.wikimedia.org/wiki/File:Val%C3%A8re_castle_in_Sion,_Switzerland,_Photo_by_Giles_Laurent.jpg



Krak des Chevaliers Castle, Syria

“Krak des Chevaliers Castle, Syria” by Vyacheslav Argenberg / http://www.vascoplanet.com/, used under CC BY 4.0
https://commons.wikimedia.org/wiki/File:Krak_des_Chevaliers_Castle,_Syria.jpg



Rousanou Monastery, Greece

“Rousanou Monastery” by Paul Stephenson, used under CC BY 2.0/ Cropped from original https://commons.wikimedia.org/wiki/File:Rousanou_Monastery,_Meteora,_Greece_(15148627963).jpg

Top 10 Ordered Ways of Attacking Strong Places



Château de Chillon and Dents du Midi, Switzerland

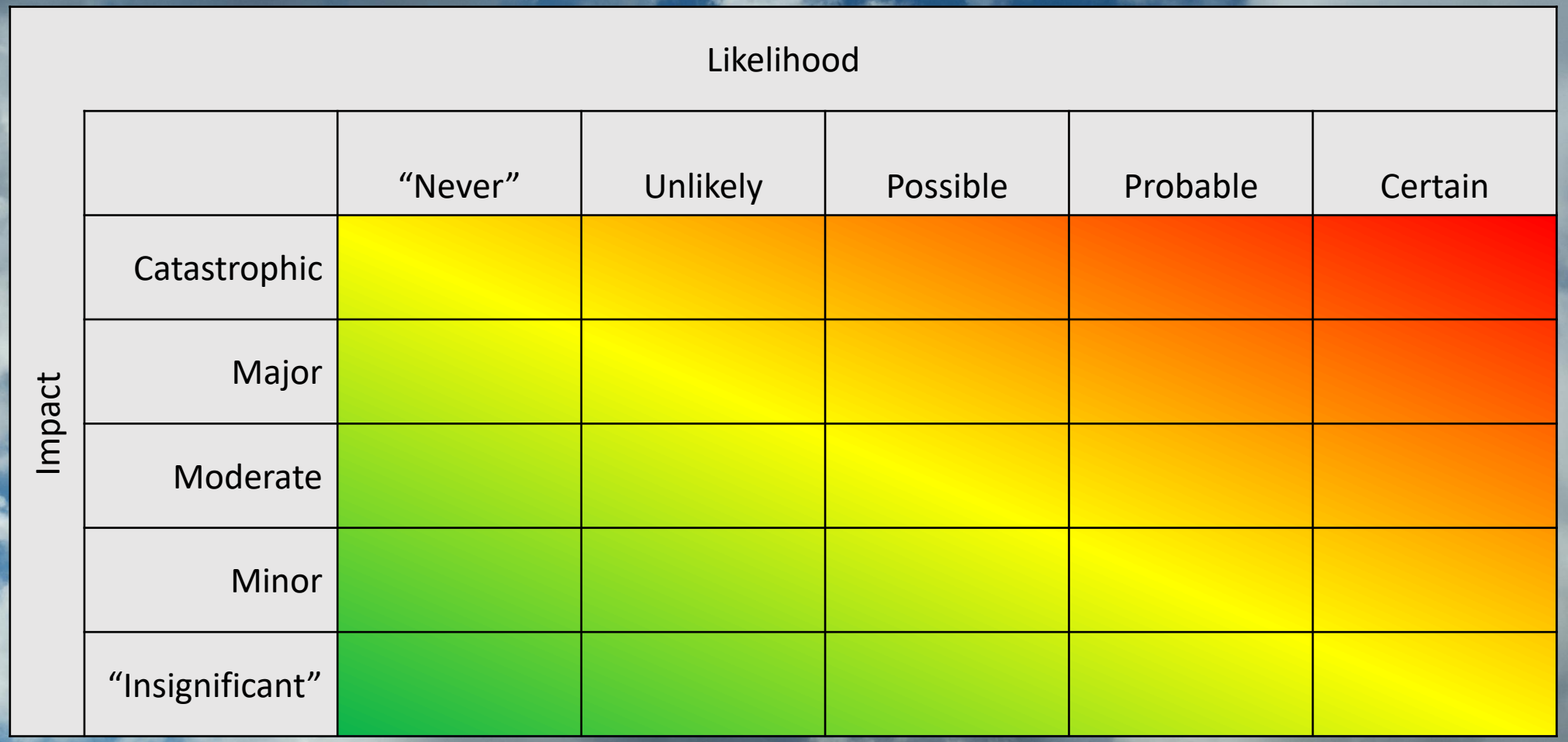
"Château de Chillon and Dents du Midi at nightfall" by Giles Laurent, used under CC BY 4.0
https://commons.wikimedia.org/wiki/File:001_Chateau_de_Chillon_and_Dents_du_Midi_Photo_by_Giles_Laurent.jpg



Mespelbrunn Castle, Germany

"Wasserschloss Mespelbrunn, 6" by Rainer Lippert
https://commons.wikimedia.org/wiki/File:Wasserschloss_Mespelbrunn,_6.jpg

Impact vs. Likelihood



“Clouds in Russia.” by Dmitry Makeev, used under CC BY-SA 4.0
https://commons.wikimedia.org/wiki/File:Clouds_in_Russia._img_421.jpg



Great Wall of China

"The Great Wall of China" by Jorge Láscar, used under CC BY 2.0/ Cropped from original https://commons.wikimedia.org/wiki/File:Lascar_The_Great_Wall_of_China_(4475570857).jpg


THE CLUB

Addressing threats

- Mitigate the threat
- Eliminate the threat
- Transfer the threat
- Accept the risk



Fortress of Città di San Marino

"The fortress of Città di San Marino" by Max_Ryazanov, used under CC BY-SA 3.0/ Cropped from original https://commons.wikimedia.org/wiki/File:Fortress_of_Guaita_2013-09-19.jpg



Framlingham Castle, England

“Framlingham Castle In Suffolk, UK” by Squeezyboy, used under CC BY 2.0/ Cropped from original https://commons.wikimedia.org/wiki/File:Franglingham_Castle_01.jpg



Framlingham Castle, England

“Postern Gate at Framlingham Caste” by Foshie, used under CC BY 2.0/ Cropped from original https://commons.wikimedia.org/wiki/File:Framlingham_Castle_Postern_Gate.jpg



Framlingham Castle, England

"Framlingham Castle, Suffolk, England" by Dave Briggs, used under CC BY-SA 2.0/ Cropped from original https://commons.wikimedia.org/wiki/File:Framlingham_Castle_-Suffolk-8.jpg

Zero trust assumptions

- The entire enterprise private network is not considered an implicit trust zone
- Devices on the network may not be owned or configurable by the enterprise
- No resource is inherently trusted
- Not all enterprise resources are on enterprise-owned infrastructure
- Remote enterprise subjects and assets cannot fully trust their local network connection
- Assets and workflows moving between enterprise and non-enterprise infrastructure should have a consistent security policy and posture



Hurst Castle, England

"Overhead view of Hurst Castle" by Hampshire County Council, used under Open Government License v3.0
https://commons.wikimedia.org/wiki/File:Overhead_view_of_Hurst_Castle.jpg

Threat Modeling Manifesto

https://www.threatmodelingmanifesto.org/

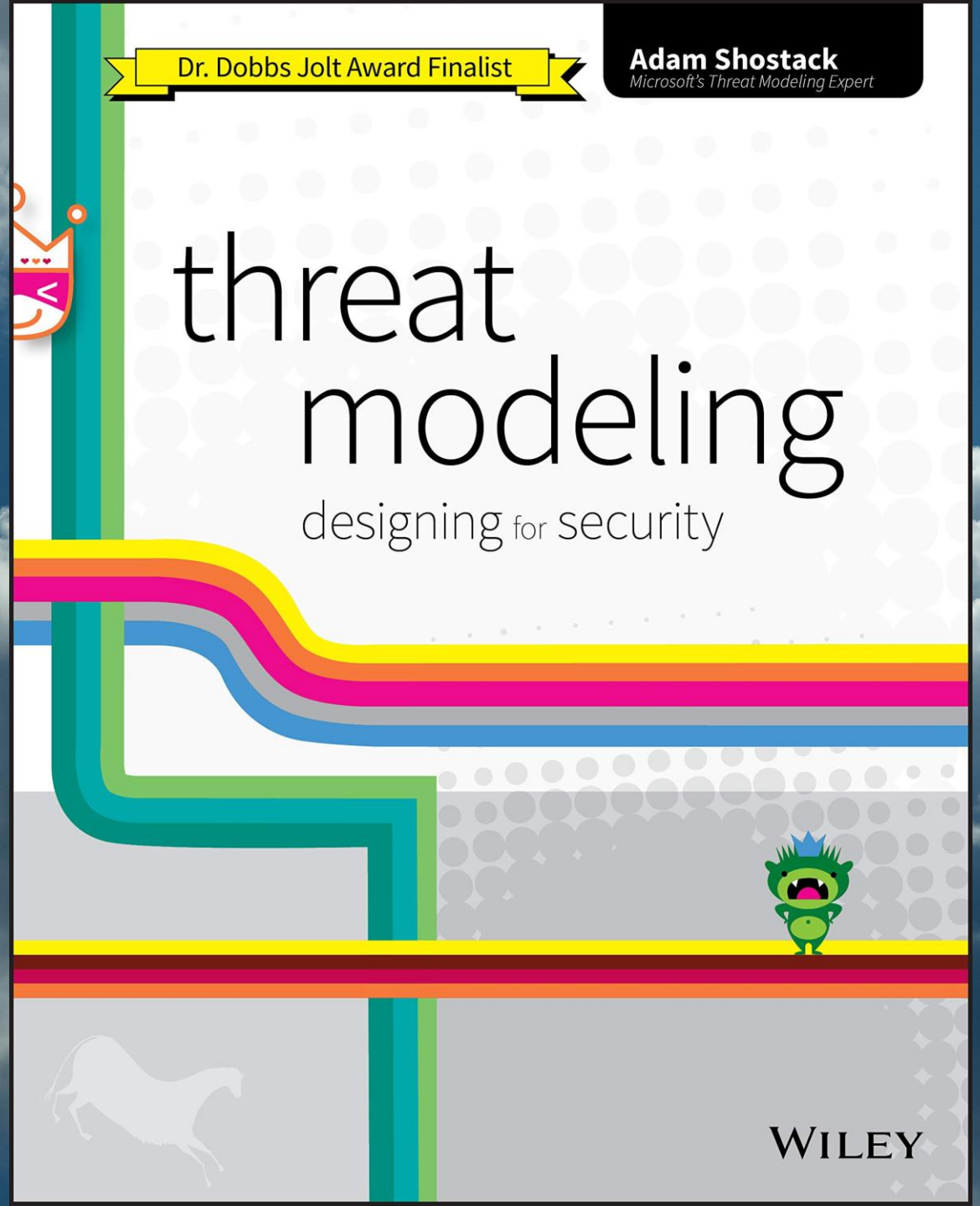
The best use of threat modeling is to improve the security and privacy of a system through early and frequent analysis.

Threat modeling does not depend on one's innate ability or unique mindset; everyone can and should do it.



Mukhrani Fortress, Georgia

"Mukhrani Fortress, vil. Mukhrani, Mtskheta-Mtianeti, Georgia" by Yasuhiro Kojima, used under CC BY-SA 4.0/ Cropped from original https://commons.wikimedia.org/wiki/File:Mukhrani_Fortress_1.jpg



@OtherDevOpsGene @techbash #TechBash

ISBN-13 978-1118809990
https://a.co/d/1Z9cp44

"Clouds in Russia." by Dmitry Makeev, used under CC BY-SA 4.0 https://commons.wikimedia.org/wiki/File:Clouds_in_Russia._img_384.jpg

STRIDE

- Spoofing
  - Pretending to be someone or something you are not
- Tampering
  - Changing data
- Repudiation
  - Not being able to prove you wrote it
- Information Disclosure
  - Data leak
- Denial of Service
  - Making a service unusable
- Elevation of Privilege
  - Gaining permissions you are not entitled to



Castle of la Punta de Amer, Spain

“Zugbrücke Castell Punta de n'Amer” by HpS, used under CC BY-SA 3.0/ Cropped from original https://commons.wikimedia.org/wiki/File:Punta14.jpg

Resources

- STRIDE
  - https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats
- OWASP Threat Dragon
  - https://www.threatdragon.com/
- PASTA
  - https://versprite.com/blog/what-is-pasta-threat-modeling/
- CAIRIS
  - https://cairis.org/
- Threagile
  - https://threagile.io/
- ThreatModeler
  - https://threatmodeler.com/



Bodiam Castle, England

"Bodiam Castle" by JamCor, used under CC BY-SA 4.0/ Cropped from original https://commons.wikimedia.org/wiki/File:Bodiam_Castle_East_Sussex.jpg

Practice idea



Threat model an alien invasion as a tabletop or lunchtime exercise

"Artwork of flying saucers attacking a metropolis" by Rosiette-Stock, public domain
https://commons.wikimedia.org/wiki/File:Alien_invasion.jpg

Questions?

Gene Gotimer
DevOps Engineer at Praeses, LLC
@OtherDevOpsGene



Himeji Castle, Japan

"Himeji Castle, Japan" by Gorgo
https://commons.wikimedia.org/wiki/File:Himeji_Castle_0804_1.jpg